

Reporte Ejecutivo de Auditoría de Seguridad

1. Resumen Ejecutivo

Score de Seguridad General: 75 / 100

Justificación del Score: El servidor opera con un sistema operativo y kernel actualizados y soportados, lo que proporciona una base de seguridad sólida. Sin embargo, se han identificado exposiciones de servicios de sistema (systemd-resolve y systemd-networkd) en puertos de red que no deberían estar accesibles externamente, lo que incrementa la superficie de ataque y representa una configuración potencialmente insegura. La presencia de usuarios interactivos requiere una gestión de credenciales robusta.

Evaluación Gerencial

El servidor auditado presenta una configuración base de seguridad favorable al utilizar Ubuntu 24.04 LTS y un kernel reciente. No obstante, se ha detectado que servicios internos como el resolvidor DNS (systemd-resolve) y el cliente DHCP (systemd-networkd) están escuchando en puertos de red. Esta exposición es inusual y potencialmente peligrosa, ya que estos servicios no están diseñados para ser accesibles desde el exterior y podrían ser explotados. Se recomienda encarecidamente revisar y restringir el acceso a estos puertos mediante un firewall, además de fortalecer las políticas de seguridad para las cuentas de usuario con acceso interactivo.

2. Hallazgos Prioritarios

- Exposición del servicio 'systemd-resolve' (DNS) en el puerto 53 (TCP/UDP), lo que podría ser una configuración insegura si está accesible externamente.
- Exposición del servicio 'systemd-network' (cliente DHCP) en el puerto 68 (UDP), una configuración altamente inusual y potencialmente crítica si está escuchando para conexiones entrantes.
- Presencia de dos cuentas de usuario con acceso interactivo (/bin/bash), lo que requiere una gestión estricta de credenciales y autenticación.

3. Matriz de Riesgos Detectados

ID	Riesgo Detectado	Nivel de Impacto	Descripción
----	------------------	------------------	-------------

R-01	Exposición Innecesaria de Servicio DNS (systemd-resolve)	Alto	El servicio 'systemd-resolve', un resolutor DNS local, está escuchando en el puerto 53 (TCP/UDP). Si este servicio está expuesto a interfaces de red públicas, podría ser abusado para ataques de amplificación DNS o utilizado como un resolutor DNS abierto no intencionado, lo que representa un riesgo de seguridad y un uso indebido de recursos.
R-02	Exposición Innecesaria de Servicio DHCP (systemd-network)	Crítico	El servicio 'systemd-networkd', que gestiona la configuración de red y actúa como cliente DHCP, está escuchando en el puerto 68 (UDP). Este puerto es típicamente utilizado por clientes DHCP para solicitar direcciones IP. Si el servidor está escuchando activamente en este puerto para conexiones entrantes, es una configuración altamente inusual y peligrosa que podría permitir ataques de suplantación de DHCP, asignación de IP no autorizada o denegación de servicio.
R-03	Cuentas de Usuario con Acceso Interactivo	Medio	Se han identificado dos cuentas de usuario ('User_2', 'User_3') con acceso interactivo a través de '/bin/bash'. Si bien esto es necesario para la administración, cada cuenta interactiva representa un punto de entrada potencial. La falta de políticas de contraseñas robustas, autenticación multifactor (MFA) o el uso exclusivo de claves SSH podría aumentar el riesgo de compromiso de credenciales.

R-04	Potencial Desactualización de Kernel y Sistema Operativo	Bajo	Aunque el sistema operativo (Ubuntu 24.04.4 LTS) y el kernel (6.8.0-124-generic) son versiones recientes y soportadas, la falta de un proceso de actualización regular y automatizado puede llevar a la exposición a vulnerabilidades recién descubiertas. Es crucial mantener el sistema y el kernel actualizados para mitigar riesgos futuros.
------	--	------	--

4. Recomendaciones Técnicas de Mitigación

■ ■ Restringir Acceso a systemd-resolve (DNS)

El servicio 'systemd-resolve' está diseñado principalmente como un resolvidor de caché local. Si está expuesto a la red externa, debe ser restringido. Se recomienda configurar un firewall (como UFW) para bloquear el puerto 53 de fuentes externas, permitiendo solo el tráfico DNS si el servidor actúa como un resolvidor autorizado para una red interna específica. En el archivo 'resolved.conf', asegúrese de que 'DNSStubListener=yes' esté comentado o configurado como 'no' si no se necesita que escuche en 127.0.0.53.

```
sudo ufw enable
sudo ufw default deny incoming
sudo ufw allow 22/tcp
sudo ufw reload
sudo nano /etc/systemd/resolved.conf
```

■ ■ Restringir Acceso a systemd-network (DHCP)

El puerto 68 es utilizado por clientes DHCP. Si 'systemd-networkd' está escuchando en este puerto para conexiones entrantes, es una configuración incorrecta. Se debe asegurar que el firewall bloquee todo el tráfico entrante no esencial, incluyendo el puerto 68 UDP, a menos que el servidor esté actuando intencionalmente como un servidor DHCP (lo cual es raro para 'systemd-networkd' en este rol). Verifique la configuración de 'systemd-networkd' para asegurar que no esté configurado para escuchar DHCP en interfaces públicas.

```
sudo ufw enable
sudo ufw default deny incoming
sudo ufw allow 22/tcp
sudo ufw reload
ip a
grep -r "DHCP" /etc/systemd/network/
```

■ ■ Fortalecer la Seguridad de Cuentas Interactivas

Implementar políticas de contraseñas fuertes (editando `/etc/pam.d/common-password`), usar autenticación basada en claves SSH en lugar de contraseñas (configurando `PasswordAuthentication no` en `/etc/ssh/sshd_config`), y habilitar `fail2ban` para mitigar ataques de fuerza bruta contra SSH. Considerar la implementación de autenticación multifactor (MFA) para una capa adicional de seguridad y deshabilitar el acceso directo de root (`PermitRootLogin no`).

```
sudo apt update && sudo apt install -y libpam-pwquality fail2ban
sudo systemctl enable fail2ban --now
sudo nano /etc/pam.d/common-password
sudo nano /etc/ssh/sshd_config
sudo systemctl restart sshd
```

■ ■ Mantener el Sistema Operativo y Kernel Actualizados

Aunque el sistema está actualizado, es fundamental establecer un régimen de actualizaciones de seguridad regular y automatizado para el sistema operativo y el kernel. Esto asegura que cualquier vulnerabilidad recién descubierta sea parcheada rápidamente, minimizando la ventana de exposición. Se recomienda reiniciar el servidor después de una actualización del kernel.

```
sudo apt update
sudo apt upgrade -y
sudo apt dist-upgrade -y
sudo apt autoremove -y
sudo reboot
```